Command-and-Control im Red Teaming: Technische Analyse aktueller Frameworks und Implikationen für Obfuscation

Projektarbeit
im Studiengang Angewandte Informatik
an der Dualen Hochschule Baden-Württemberg Mannheim

von
Gabriel Ralf Ricarte Lanz

Abgabedatum: 27.08.2026

Bearbeitungszeitraum	08.01.2026-27.08.2026
Matrikelnummer, Kurs	6613445, TINF24AI1
Ausbildungsfirma	ABB AG
Betreuer	Tran, Jake
Unterschrift Betreuer	_____

Sperrvermerk

Der Inhalt dieser Arbeit darf weder als Ganzes noch in Auszügen Personen außerhalb des Prüfungsprozesses und des Evaluationsverfahrens zugänglich gemacht werden, sofern keine anders lautende Genehmigung des Dualen Partners vorliegt.

Erklärung

Ich versichere hiermit, dass ich meine Bachelorarbeit (bzw. Projektarbeit oder Studienarbeit bzw. Hausarbeit) mit den Themen: Automatisierte Analyse und Vergleich von Gruppenrichtlinienobjekten & Evaluierung von Verschleierungstechniken für Penetrationstests selbstständig verfasst und keine anderen als die angegebenen Quellen und Hilfsmittel benutzt habe. Ich versichere zudem, dass die eingereichte elektronische Fassung mit der gedruckten Fassung übereinstimmt.

Frankfurt am Main, den 27.08.2026

Ort, Datum	Unterschrift

Abstract

The present report focuses on the analysis of modern Command-and-Control (C2) frameworks in the context of Red Team operations. C2 infrastructures represent a core component of realistic attack simulations, as they enable the centralized control of compromised systems and the execution of post-exploitation activities.
The work provides a technical examination of contemporary C2 frameworks, with a particular focus on the Sliver framework. In addition, established solutions such as Metasploit and Cobalt Strike are comparatively assessed to identify architectural differences, operational characteristics, and typical use cases. The results contribute to evaluating the suitability of modern C2 frameworks for penetration testing as a service offering within the Service Central Cyber-Security (SZC) department and provide a foundation for further investigations in the area of payload and communication obfuscation.

Inhaltsverzeichnis

Sperrvermerk **i**

Erklärung zur Eigenleistung **ii**

Abstract **iii**

Abstract **iii**

Inhaltsverzeichnis **iv**

Abbildungsverzeichnis **vi**

Tabellenverzeichnis (Eigene Darstellung) **vii**

Abkürzungsverzeichnis **viii**

Überblick der Tätigkeiten der Praxisphasen **ix**

Vorwort **x**

1 Einleitung **1**
1.1 Ziel der Praxisarbeit 1
1.2 Einordnung von Command-and-Control (C2) im Red Teaming . 1
1.3 Relevanz moderner C2-Frameworks für realistische Angreifersimulationen 2

2 Theoretische Grundlagen **4**
2.1 Command-and-Control (C2) - Grundkonzept 4
2.1.1 Definition und Zweck von C2 4
2.1.2 Klassischer Kill-Chain Kontext 4
2.1.3 Beaconing und Kommunikation in C2-Frameworks 4
2.2 Anforderungen an moderne C2-Frameworks 5
2.2.1 Stealth und OPSEC 5
2.2.2 Modularität 6
2.2.3 Umgehung von EDR/AV-Systemen 6
2.2.4 Flexibilität und Anpassungsfähigkeit 6

3 Überblick über gängige C2-Frameworks **8**
3.1 Metasploit (MSF) 8
3.2 Cobalt Strike 9
3.3 Sliver 9

4 Sliver - Detaillierte Analyse **11**
4.1 Architektur 11
4.1.1 Sliver Server 11
4.1.2 Sliver Client 12
4.1.3 Implantate 13
4.2 Kommunikation 14
4.2.1 Payloads 14
4.2.2 Post-Exploitation 14
4.3 Stealth und OPSEC 14

5 Vergleichende Gegenüberstellung der C2-Frameworks **15**
5.1 Techischer Vergleich 15
5.2 Detection und Blue-Team-Sicht 15
5.3 Einsatzszenarien 15

6 Praxisbezug **16**
6.1 16

7 Obfuscation als logische Weiterentwicklung **17**
7.1 Identifizierte Schwachstellen moderner C2s 17
7.2 Motivation für Obfuscation 17
7.3 Ausblick auf kommende Praxisarbeit 17

8 Fazit **18**

Abbildungsverzeichnis

1 Cyber Kill Chain 2
2 Sliver Server CLI 11
3 Sliver Client CLI 13
4 Server-Client Modell 14

Tabellenverzeichnis

1 Abkürzungsverzeichnis viii
2 Übersicht der Tätigkeiten während der Praxisphasen ix

Abkürzungsverzeichnis

Abkürzung	Bedeutung
ABB	Asea Brown Boveri
AD	Active Directory
IT	Informations Technologie
PAEN	Process Automation Energy Industries
SZC	Service Zentralbereich Cyber-Security
OPSEC	Operational Security
C2	Command and Control
EDR	Endpoint Detection and Response
SOC	Security Operations Center
SIEM	Security Information and Event Management

Tabelle 1: Abkürzungsverzeichnis

Überblick der Tätigkeiten der Praxisphasen

Nr.	Tätigkeit	Zeitraum	Praxisphase
1	Workshop der SZC Abteilung am Standort Frankfurt Praunheim	26.01.26-30.01.26	3
2	Themenbearbeitung: Social Engineering als Service Leistung	26.01.26-30.01.26	3
3	Themenbearbeitung: Command and Control Frameworks im Kontext von Penetration Tests	30.01.26 - 17.03.26	3

Tabelle 2: Übersicht der Tätigkeiten während der Praxisphasen

Vorwort

Die in dieser Arbeit beschriebenen Tätigkeiten wurden im Rahmen der dritten Praxisphase bei **ASEA Brown Boveri AG (ABB)** durchgeführt. Der Praxiszeitraum erstreckte sich über die vereinbarte Dauer der dritten Praxisphase. Die Tätigkeiten fanden an den Standorten Frankfurt am Main und Mannheim statt und wurden in der Abteilung **Process Automation Energy Industries (PAEN)**, konkret im **Service Zentralbereich Cyber-Security (SZC)**, unter der fachlichen Anleitung der betrieblichen Betreuer Philip Dosch und Jake Tran durchgeführt.

Gegenstand dieser Praxisarbeit ist die Analyse moderner **Command-and-Control-Infrastrukturen (C2)** im Kontext von Red-Team-Operationen. Der Schwerpunkt liegt auf der technischen Betrachtung aktueller C2-Frameworks, wobei insbesondere das Framework **Sliver** detailliert analysiert wird. Ergänzend erfolgt eine vergleichende Einordnung weiterer verbreiteter Lösungen, darunter unter anderem **Metasploit** und **Cobalt Strike**, um Gemeinsamkeiten, Unterschiede sowie jeweilige Einsatzszenarien herauszuarbeiten.

Im Rahmen der Arbeit werden zentrale Aspekte moderner C2-Frameworks untersucht, darunter Architekturkonzepte, Kommunikationsmechanismen, Payload-Generierung sowie operative Gesichtspunkte im Hinblick auf Stealth und OPSEC. Ziel ist es, ein fundiertes Verständnis für die Funktionsweise und den praktischen Einsatz dieser Infrastrukturen in realistischen Red-Team-Szenarien zu vermitteln.

Die Analyse zeigt zugleich, dass trotz fortschreitender Entwicklung moderner C2-Frameworks weiterhin erkennbare Schwachstellen in Bezug auf Erkennbarkeit, Signaturbildung und Verhaltensanalyse bestehen. Diese Erkenntnisse verdeutlichen die Notwendigkeit zusätzlicher Maßnahmen zur Tarnung von Payloads und Kommunikationsmustern, insbesondere im Umfeld zunehmend leistungsfähiger Endpoint-Detection-and-Response-Systeme.

Aufbauend auf den Ergebnissen dieser Praxisphase ergibt sich eine inhaltliche Überleitung zur vierten Praxisphase, in der der Fokus auf der vertieften Auseinandersetzung mit **Obfuscation-Techniken** liegen wird. Geplant ist dabei die Konzeption und Entwicklung einer eigenen **Obfuscation-Toolbox**, welche gezielt auf die im Rahmen dieser Arbeit identifizierten Schwachstellen moderner C2-Infrastrukturen eingeht und deren Einsatz in Red-Team-Operationen weiter optimiert.

Abschließend möchte ich mich bei meinen Praxisbetreuern, meinem Vorgesetzten sowie bei allen Kolleginnen und Kollegen der Abteilung bedanken, die mich während der dritten Praxisphase fachlich unterstützt haben und jederzeit für einen offenen Austausch zur Verfügung standen.

1 Einleitung

1.1 Ziel der Praxisarbeit

Die zunehmende Vernetzung industrieller Steuerungs- und Automatisierungssysteme führt zu einer wachsenden Angriffsfläche, insbesondere in sicherheitskritischen Betriebsumgebungen. Unternehmen, die im Bereich der Operational Technology (OT) und kritischer Infrastrukturen (KRITIS) tätig sind, stehen dabei vor der Herausforderung, sowohl regulatorische Anforderungen als auch steigende Bedrohungen durch hochentwickelte Angreifer zu adressieren. Vor diesem Hintergrund gewinnt die realistische Bewertung der eigenen Sicherheitsmaßnahmen zunehmend an Bedeutung.

Gegenstand dieser Praxisarbeit ist die technische Analyse moderner Command-and-Control-Frameworks (C2) im Kontext von Red-Team-Operationen. Im Fokus stehen dabei Architekturkonzepte, Kommunikationsmechanismen sowie operative Eigenschaften aktueller C2-Lösungen. Exemplarisch wird das Framework Sliver detailliert untersucht und mit weiteren etablierten Frameworks wie Metasploit und Cobalt Strike vergleichend eingeordnet.

Auf Basis dieser Analyse werden die Einsatzmöglichkeiten moderner C2-Frameworks im Rahmen realitätsnaher Angriffssimulationen bewertet. Dabei werden sowohl technische Kriterien als auch operationelle Gesichtspunkte wie Skalierbarkeit, Flexibilität und Stealth betrachtet. Die gewonnenen Erkenntnisse dienen als Grundlage für die Einordnung des praktischen Nutzens von C2-Infrastrukturen in professionellen Sicherheitsprüfungen und im Kontext angebotener Penetrationstests.

1.2 Einordnung von Command-and-Control (C2) im Red Teaming

Im Red Teaming stellt Command-and-Control eine zentrale Phase innerhalb der Cyber Kill Chain[1] dar. Nach erfolgreicher Kompromittierung eines Zielsystems ermöglicht eine C2-Infrastruktur die fortlaufende Steuerung kompromittierter Systeme, die Durchführung weiterer Aktionen sowie die Koordination komplexer Angriffsszenarien. Ohne eine funktionierende C2-Kommunikation ist eine nachhaltige und realitätsnahe Simulation moderner Angreifer nicht möglich.

Abbildung 1: Cyber Kill Chain

Im Gegensatz zu klassischen Penetrationstests, die häufig auf die Identifikation einzelner Schwachstellen fokussiert sind, zielt Red Teaming auf die Nachbildung vollständiger Angriffsabläufe ab. C2-Frameworks übernehmen hierbei die Rolle der zentralen Steuerungsinstanz und bilden die technische Grundlage für Post-Exploitation-Aktivitäten, laterale Bewegungen und persistente Zugriffsmechanismen. Ihre Ausgestaltung beeinflusst maßgeblich die Realitätsnähe und Aussagekraft einer Red-Team-Operation.

1.3 Relevanz moderner C2-Frameworks für realistische Angreifersimulationen

Mit dem Inkrafttreten der NIS-2-Richtlinie verschärfen sich die regulatorischen Anforderungen an Betreiber kritischer Infrastrukturen sowie an Unternehmen, die Dienstleistungen für diese bereitstellen. Insbesondere im OT- und KRITIS-Umfeld rücken Aspekte wie Angriffserkennung, Resilienz und kontinuierliche Sicherheitsbewertung stärker in den Fokus. ABB agiert in diesem Umfeld als Anbieter und Integrator industrieller Automatisierungs- und Prozessleitsysteme, deren Verfügbarkeit, Integrität und Sicherheit von zentraler Bedeutung sind.

Für den Service Zentralbereich Cyber-Security (SZC) ergibt sich daraus die Notwendigkeit, Sicherheitsprüfungen über rein technische Schwachstellenanalysen hinaus zu erweitern. Moderne C2-Frameworks ermöglichen es, realistische Angreiferverhalten nachzubilden und die Wirksamkeit bestehender Sicherheitsmaßnahmen unter praxisnahen Bedingungen zu evaluieren. Insbesondere im Rahmen von Penetrationstests als Serviceleistung bieten C2-Infrastrukturen die Möglichkeit, komplexe Angriffsszenarien kontrolliert zu simulieren und deren Auswirkungen auf IT- und OT-Umgebungen zu analysieren.

Die in dieser Praxisarbeit untersuchten C2-Frameworks leisten somit einen Beitrag zur Erhöhung der Aussagekraft von Sicherheitsprüfungen im regulierten Umfeld. Gleichzeitig bilden sie eine technische Grundlage für weiterführende Fragestellungen, etwa im Bereich der Tarnung von Payloads und Kommunikationsmustern, die im Kontext zunehmender Detektionsmechanismen an Bedeutung gewinnen.

2 Theoretische Grundlagen

2.1 Command-and-Control (C2) - Grundkonzept

2.1.1 Definition und Zweck von C2

Command-and-Control (C2) bezeichnet im Kontext von Cyberangriffen die Gesamtheit der Mechanismen und Infrastrukturen, die es einem Angreifer ermöglichen, kompromittierte Systeme zentral zu steuern. Nach erfolgreicher Kompromittierung eines Zielsystems dient eine C2-Infrastruktur dazu, Befehle an Implantate oder Schadsoftware zu übermitteln, Rückmeldungen zu empfangen und weitere Aktionen zu koordinieren. C2 stellt somit die kommunikative Verbindung zwischen Angreifer und Zielsystem dar und ist eine wesentliche Voraussetzung für nachhaltige und zielgerichtete Angriffe.[2]

2.1.2 Klassischer Kill-Chain Kontext

C2 ist als eigenständige Phase innerhalb der klassischen Cyber Kill Chain zu verstehen. Die Kill Chain beschreibt einen sequenziellen Angriffsablauf, der von der Aufklärung über die initiale Kompromittierung bis hin zur Zielerreichung reicht. In diesem Modell folgt die Command-and-Control-Phase typischerweise auf die erfolgreiche Ausführung und Installation eines Angriffsartefakts.

Wie in Abbildung 1 dargestellt, bildet C2 das Bindeglied zwischen der initialen Kompromittierung und den eigentlichen Angriffsaktionen. Erst durch eine funktionierende C2-Kommunikation wird es möglich, kompromittierte Systeme dauerhaft zu kontrollieren, weitere Befehle auszuführen und situativ auf Veränderungen in der Zielumgebung zu reagieren. Aus Sicht der Verteidigung stellt die C2-Phase zugleich einen zentralen Ansatzpunkt für Detektion und Unterbrechung von Angriffen dar.

Im Red Teaming wird dieser Kontext bewusst genutzt, um nicht nur einzelne Schwachstellen zu identifizieren, sondern vollständige Angriffsketten realistisch abzubilden. Die Qualität und Ausgestaltung der C2-Infrastruktur hat dabei direkten Einfluss auf die Aussagekraft der gesamten Angreifersimulation.

2.1.3 Beaconing und Kommunikation in C2-Frameworks

Die Kommunikation zwischen kompromittierten Systemen und einer Command-and-Control-Infrastruktur bildet einen zentralen Bestandteil moderner C2-Frameworks. Ziel ist es, Befehle und Rückmeldungen zuverlässig sowie möglichst unauffällig zu übertragen. Zu diesem Zweck unterstützen aktuelle Frameworks unterschiedliche Kommunikationsprotokolle, die sich an legitimen Netzwerkverkehr anlehnen und verschiedene Einsatzszenarien abdecken.

Ein verbreitetes Kommunikationsmodell ist das Beaconing, bei dem kompromittierte Systeme in regelmäßigen oder adaptiven Intervallen selbstständig eine

Verbindung zum C2-Server herstellen. Dieses Modell begünstigt ausgehenden Netzwerkverkehr und ist insbesondere in Umgebungen mit restriktiven Firewall-Regeln von Vorteil. Demgegenüber stehen sessionbasierte Modelle mit persistenten Verbindungen, die eine unmittelbare Interaktion ermöglichen, jedoch eine erhöhte Erkennbarkeit aufweisen können.

Zur Umsetzung dieser Modelle nutzen C2-Frameworks verschiedene Protokolle. Häufig kommt TLS-geschützter HTTP(S)-Verkehr zum Einsatz, da dieser in den meisten Netzwerken erlaubt ist und sich gut in regulären Web-Traffic integrieren lässt. Ergänzend werden DNS-basierte Mechanismen verwendet, um auch in stark eingeschränkten Netzwerken eine grundlegende Kommunikation zu ermöglichen. Moderne Frameworks unterstützen zudem verschlüsselte Tunnelverfahren wie WireGuard, die eine robuste und performante Kommunikation bei gleichzeitig hohem Sicherheitsniveau bieten.

Die detaillierte Betrachtung dieser Kommunikationsmechanismen sowie deren operative Auswirkungen erfolgt in den nachfolgenden Abschnitten dieser Arbeit.

2.2 Anforderungen an moderne C2-Frameworks

Moderne Command-and-Control-Frameworks müssen eine Vielzahl technischer und operationeller Anforderungen erfüllen, um in realistischen Angriffsszenarien einsetzbar zu sein. Insbesondere im Kontext professioneller Sicherheitsprüfungen ist es erforderlich, dass C2-Infrastrukturen sowohl funktional leistungsfähig als auch anpassbar und kontrollierbar sind. Die folgenden Kriterien stellen zentrale Anforderungen dar, die bei der Bewertung moderner Frameworks berücksichtigt werden müssen.

2.2.1 Stealth und OPSEC

Eine der wesentlichsten Anforderungen an moderne C2-Frameworks ist ein hohes Maß an Stealth. Darunter ist die Fähigkeit zu verstehen, Kommunikations- und Laufzeitverhalten so zu gestalten, dass sie möglichst wenig Auffälligkeiten gegenüber Sicherheitsmechanismen erzeugen. In modernen IT- und insbesondere OT-Umgebungen werden Netzwerkverkehr, Prozessverhalten und Speicheraktivitäten zunehmend überwacht. Auffällige Muster können daher schnell zu einer Detektion führen.

Um diesem Risiko zu begegnen, müssen C2-Frameworks in der Lage sein, ihre Kommunikation und ihr Verhalten an die jeweilige Zielumgebung anzupassen. Dies umfasst die Nutzung von legitimen Protokollen, die Integration in regulären Netzwerkverkehr sowie die Vermeidung von auffälligen Mustern in der Prozess- und Speicheraktivität. Darüber hinaus ist eine sorgfältige OPSEC (Operational Security) unerlässlich, um die Angriffsinfrastruktur vor Entdeckung zu schützen und die Effektivität der Simulation zu gewährleisten.

2.2.2 Modularität

Modularität ist ein weiteres zentrales Kriterium für moderne C2-Frameworks. Ein modularer Aufbau ermöglicht es, verschiedene Komponenten wie Kommunikationsprotokolle, Verschlüsselungsmechanismen oder Implantattypen flexibel zu kombinieren und an spezifische Anforderungen anzupassen. Dies erhöht nicht nur die Einsatzmöglichkeiten, sondern erleichtert auch die Wartung und Weiterentwicklung der C2-Infrastruktur.

2.2.3 Umgehung von EDR/AV-Systemen

Die zunehmende Verbreitung von Endpoint Detection and Response (EDR) sowie verhaltensbasierten Antivirenlösungen verschärft die Anforderungen an C2-Frameworks zusätzlich. Moderne Sicherheitsprodukte analysieren Prozesse, Speicherzugriffe und Netzwerkaktivitäten anhand heuristischer Modelle und Anomalieerkennung. Vor diesem Hintergrund genügt es nicht, lediglich bekannte Signaturen zu vermeiden.

Vielmehr muss ein C2-Framework in der Lage sein, generische Erkennungsmerkmale zu minimieren. Dies betrifft sowohl die Art der Prozessausführung als auch das Kommunikationsverhalten. Die zuvor beschriebene Modularität unterstützt dies, da sie es erlaubt, Mechanismen situationsabhängig anzupassen. Stealth, OPSEC und Modularität wirken somit zusammen, um die Wahrscheinlichkeit einer Detektion zu reduzieren und gleichzeitig realistische Angriffsszenarien zu ermöglichen.

Im Rahmen professioneller Sicherheitsprüfungen ist dieser Aspekt besonders relevant: Wird ein Framework unmittelbar durch Standardkonfiguration erkannt, lassen sich nur begrenzte Rückschlüsse auf die tatsächliche Resilienz einer Umgebung ziehen.

2.2.4 Flexibilität und Anpassungsfähigkeit

Die genannten Anforderungen münden schließlich in der übergeordneten Notwendigkeit der Flexibilität. IT- und insbesondere OT-Umgebungen unterscheiden sich stark hinsichtlich Netzwerksegmentierung, Sicherheitsniveau und regulatorischer Rahmenbedingungen. Ein C2-Framework muss daher in der Lage sein, sich an unterschiedliche technische und organisatorische Gegebenheiten anzupassen.

Flexibilität umfasst sowohl die Unterstützung verschiedener Betriebssysteme und Kommunikationsprotokolle als auch die Möglichkeit, unterschiedliche Angriffsszenarien abzubilden. Während in einer Umgebung kurzfristige Interaktion im Vordergrund stehen kann, ist in einer anderen die Simulation persistenter, langfristiger Zugriffe entscheidend. Die Fähigkeit, Kommunikationsmodelle, Module und Einsatzparameter situationsabhängig zu konfigurieren, ist daher essenziell.

Gerade im regulierten Umfeld, etwa im Kontext von NIS-2 oder kritischen

Infrastrukturen, ist eine kontrollierte und nachvollziehbare Anpassungsfähigkeit von Bedeutung. Ein modernes C2-Framework muss nicht nur technisch leistungsfähig sein, sondern auch strukturiert einsetzbar, dokumentierbar und in bestehende Sicherheitsprozesse integrierbar bleiben.

3 Überblick über gängige C2-Frameworks

3.1 Metasploit (MSF)

Metasploit (MSF) zählt zu den bekanntesten und am weitesten verbreiteten Frameworks in der Sicherheitscommunity. Ursprünglich als Plattform zur Entwicklung und Integration von Exploits konzipiert, hat es sich zu einem umfassenden Werkzeug für Penetrationstests und angriffsnahe Sicherheitsanalysen entwickelt. Das Framework stellt eine Vielzahl von Modulen bereit, darunter Exploits, Payloads, Encoders und Auxiliary-Komponenten, und deckt damit insbesondere die Phase der Initialkompromittierung strukturiert ab [3]. Command-and-Control-Funktionalitäten werden primär über das Meterpreter-Modul realisiert.

Meterpreter ermöglicht eine interaktive, sessionbasierte Steuerung kompromittierter Systeme und unterstützt unter anderem Dateioperationen, Prozessinteraktionen sowie Speicherzugriffe. Die unmittelbare und latenzarme Ausführung von Befehlen ist insbesondere in klassischen Penetrationstests vorteilhaft, da Schwachstellen schnell validiert und Auswirkungen anschaulich demonstriert werden können. Gleichzeitig ist zu berücksichtigen, dass persistente Sessions im Vergleich zu Beaconing-basierten Modellen eine erhöhte Netzwerkauffälligkeit verursachen können. Dauerhafte Verbindungen oder interaktive Shells lassen sich in überwachten Umgebungen leichter identifizieren, insbesondere bei Einsatz moderner EDR- oder Netzwerküberwachungssysteme. Die hohe Interaktivität stellt somit einen operativen Vorteil dar, kann jedoch in realitätsnahen Red-Team-Szenarien mit erhöhten Detektionsrisiken verbunden sein.

Im Unterschied zu speziell für langfristige Red-Team-Operationen entwickelten Frameworks liegt der Schwerpunkt von Metasploit weniger auf ausgeprägter OPSEC oder adaptiven Kommunikationsmodellen. Standardisierte Payloads und bekannte Artefakte führen in produktiven Umgebungen nicht selten zu einer schnellen Erkennung. Zwar bestehen Anpassungs- und Erweiterungsmöglichkeiten, jedoch war eine langfristig unauffällige C2-Infrastruktur nicht primärer Designfokus des Frameworks.

Aus wirtschaftlicher Sicht ist zwischen dem frei verfügbaren Metasploit Framework und kommerziellen Varianten wie Metasploit Pro zu unterscheiden. Während das Open-Source-Framework kostenfrei genutzt werden kann, bieten die kostenpflichtigen Versionen zusätzliche Funktionen, etwa im Bereich automatisierter Berichterstellung, Web-basierter Verwaltung und Projektmanagement. Diese werden üblicherweise im Rahmen jährlicher Lizenzmodelle angeboten und können regionalen Prüfungen unterliegen. Für Organisationen ergibt sich daher eine Abwägung zwischen funktionalem Mehrwert und Lizenzkosten.

3.2 Cobalt Strike

Cobalt Strike wurde gezielt für professionelle Red-Team-Operationen entwickelt und hat sich in den vergangenen Jahren als etablierter Standard im kommerziellen Red-Team-Umfeld positioniert. Im Gegensatz zu Metasploit, dessen Ursprung in der strukturierten Exploit-Integration liegt, steht bei Cobalt Strike die durchführung fortgeschrittener Angriffe über mehrere Phasen der Kill Chain hinweg im Vordergrund. Der Fokus liegt damit weniger auf der initialen Schwachstellenausnutzung als auf nachhaltiger Post-Exploitation und kontrollierter Steuerung kompromittierter Systeme.

Zentrales Element der Architektur ist das sogenannte Beacon-Konzept. Anders als primär sessionbasierte Modelle setzt Cobalt Strike auf eine adaptive Beaconing-Kommunikation, die über verschiedene Transportmechanismen wie HTTP(S), DNS oder SMB erfolgen kann. Durch konfigurierbare Intervalle, verschleierte Datenstrukturen und flexible Infrastrukturparameter lässt sich das Kommunikationsverhalten an die jeweilige Zielumgebung anpassen. Dieses Modell reduziert im Vergleich zu persistenten Sessions die Netzwerkauffälligkeit und eignet sich insbesondere für längerfristige, realitätsnahe Angriffssimulationen.

Neben der Kommunikationsarchitektur bietet Cobalt Strike umfangreiche Funktionen zur Teamkoordination. Mehrere Operatoren können parallel auf einem Teamserver arbeiten, wodurch komplexe Angriffsszenarien strukturiert geplant und durchgeführt werden können. Ergänzt wird dies durch integrierte Mechanismen zur Verwaltung von Beacons, zur Ausführung von Post-Exploitation-Aktivitäten sowie zur Anpassung operativer Parameter. Diese Kombination aus technischer Flexibilität und organisatorischer Struktur macht das Framework besonders leistungsfähig im professionellen Einsatz.

Gleichzeitig ist zu berücksichtigen, dass Cobalt Strike aufgrund seiner weiten Verbreitung verstärkt im Fokus von Sicherheitsanbietern steht. Standardisierte Konfigurationen oder unzureichend angepasste Profile können daher ebenfalls zu einer schnellen Detektion führen. Außerdem ist die kommerzielle Lizenzierung mit jährlichen Kosten verbunden, die je nach Umfang der Nutzung und regionalen Gegebenheiten variieren können. Für Organisationen, die auf professionelle Red-Team-Operationen setzen, stellt sich daher die Frage nach dem Kosten-Nutzen-Verhältnis im Vergleich zu alternativen Lösungen.

3.3 Sliver

Sliver stellt eine moderne, Open-Source-basierte Command-and-Control-Lösung dar, die von Beginn an mit dem Ziel entwickelt wurde, flexible und modulare Red-Team-Infrastrukturen bereitzustellen. Im Unterschied zu Metasploit, das seinen Schwerpunkt auf Exploit-Integration legt, und Cobalt Strike, das als kommerzielles Produkt stark auf koordinierte Red-Team-Operationen ausgerichtet ist, positioniert sich Sliver als technisch leistungsfähige, zugleich kostenfreie

Alternative mit infrastrukturellem Fokus.

Architektonisch unterstützt Sliver sowohl Beaconing- als auch sessionbasierte Kommunikationsmodelle und bietet eine breite Auswahl an Transportprotokollen, darunter TLS-gesicherter HTTP(S)-Verkehr, DNS sowie WireGuard-basierte Tunnel. Diese Vielfalt ermöglicht eine flexible Anpassung an unterschiedliche Netzwerkbedingungen und Sicherheitsanforderungen. Besonders hervorzuheben ist die plattformübergreifende Ausrichtung des Frameworks, das Implantate für verschiedene Betriebssysteme generieren kann und damit heterogene Zielumgebungen adressiert.

Ein wesentliches Merkmal von Sliver ist die konsequente Modularität der Architektur. Kommunikationsmechanismen, Implantate und Erweiterungen sind klar strukturiert voneinander getrennt, was eine gezielte Anpassung einzelner Komponenten erlaubt. Darüber hinaus unterstützt Sliver einen Multi-Operator-Betrieb, wodurch parallele Arbeit mehrerer Tester innerhalb einer gemeinsamen Infrastruktur möglich ist. Diese Eigenschaften rücken das Framework funktional näher an kommerzielle Lösungen heran, ohne an ein Lizenzmodell gebunden zu sein.

Aus wirtschaftlicher Sicht stellt der Open-Source-Charakter einen signifikanten Unterschied zu Cobalt Strike dar. Es fallen keine Lizenzkosten pro Operator oder Server an, was insbesondere für interne Sicherheitsabteilungen oder Organisationen mit mehreren Testumgebungen von Vorteil sein kann. Gleichzeitig liegt die Verantwortung für Wartung, Konfiguration und Infrastrukturdesign vollständig beim betreibenden Team, da kein kommerzieller Support im klassischen Sinne vorgesehen ist.

Im Vergleich zu Metasploit ist Sliver weniger auf die initiale Ausnutzung von Schwachstellen fokussiert, sondern stärker auf die strukturierte Steuerung und Verwaltung kompromittierter Systeme ausgelegt. Im Vergleich zu Cobalt Strike bietet es ähnliche konzeptionelle Ansätze hinsichtlich Beaconing und Teamfähigkeit, jedoch in einem offenen und anpassbaren Entwicklungsmodell.

Die detaillierte Analyse der Architektur, Kommunikationsmechanismen sowie der operativen Eigenschaften von Sliver erfolgt im nachfolgenden Kapitel. Dort wird insbesondere untersucht, inwiefern das Framework die zuvor definierten Anforderungen an moderne C2-Infrastrukturen erfüllt.

4 Sliver - Detaillierte Analyse

Nach der vergleichenden Einordnung gängiger Command-and-Control-Frameworks im vorherigen Kapitel erfolgt nun eine vertiefte Analyse des Frameworks Sliver. Ziel dieses Kapitels ist es, die architektonischen Konzepte, Kommunikationsmechanismen und operativen Eigenschaften des Systems systematisch zu untersuchen und im Kontext der zuvor definierten Anforderungen an moderne C2-Infrastrukturen zu bewerten.

4.1 Architektur

Die Architektur von Sliver folgt einem klar strukturierten Client-Server-Modell, das auf eine logische Trennung zwischen Steuerungsinstanz, Operator-Zugriff und kompromittierten Endsystemen ausgelegt ist. Dieses Design unterstützt sowohl Skalierbarkeit als auch operationelle Sicherheit und bildet die Grundlage für den modularen Aufbau des Frameworks [4].

4.1.1 Sliver Server

Der Sliver Server bildet die zentrale Steuerungsinstanz der gesamten C2-Infrastruktur. Er verwaltet den operativen Zustand laufender Kampagnen und übernimmt die Koordination zwischen Operatoren und kompromittierten Endsystemen. Ein wesentliches Element ist die interne Zustandsverwaltung, die aktive Beacons, Sessions, Listener sowie generierte Implantate strukturiert erfasst und verwaltet. Diese interne Datenhaltung ermöglicht eine konsistente Verwaltung paralleler Verbindungen und stellt sicher, dass Aufgaben, Jobs und Statusinformationen nachvollziehbar gespeichert werden.

Abbildung 2: Sliver Server CLI

Darüber hinaus ist der Server für das Starten und Stoppen aktiver Listener verantwortlich. Listener definieren die Kommunikationsendpunkte, über die Implantate eine Verbindung zur C2-Infrastruktur herstellen können. Durch die

Möglichkeit, mehrere Listener mit unterschiedlichen Transportprotokollen parallel zu betreiben, wird eine flexible und segmentierte Infrastruktur unterstützt.

Die Kommunikation zwischen Server und Operator-Clients erfolgt über gRPC[1] und ist durch gegenseitige TLS-Authentifizierung abgesichert. Dieses Design erlaubt eine strukturierte, typisierte Befehlsübertragung sowie eine klare Identitätsprüfung der zugreifenden Operatoren. Der Server fungiert somit nicht nur als Vermittlungsinstanz, sondern als kontrolliertes Verwaltungs- und Sicherheitszentrum der gesamten C2-Architektur.

4.1.2 Sliver Client

Der Sliver Client stellt die operative Schnittstelle für Operatoren dar und ist primär als Kommandozeileninterface (CLI) implementiert. Über den Client werden Listener konfiguriert, Implantate generiert und aktive Beacons oder Sessions verwaltet. Die Trennung zwischen Server und Client ermöglicht es, mehrere Operatoren parallel mit derselben Infrastruktur arbeiten zu lassen.

Jeder Operator verfügt über eine individuelle Konfigurationsdatei, die kryptografisches Material enthält und eine eindeutige Identitätszuordnung erlaubt. Dieses Multi-Operator-Modell unterstützt koordinierte Red-Team-Operationen und gewährleistet gleichzeitig Zugriffskontrolle.

[1] gRPC (Google Remote Procedure Call) ist ein Open-Source Framework für Remote Procedure Calls. Es ermöglicht Anwendungen, Funktionen auf einem Server so aufzurufen, als wären sie lokal. [5]

Abbildung 3: Sliver Client CLI

Ein zentraler Bestandteil der Client-Funktionalität ist die Generierung von Implantaten. Dabei werden Kommunikationsparameter, Transportprotokolle sowie Betriebsmodi bereits zur Compile-Zeit definiert. Zusätzlich übernimmt der Client die Verwaltung aktiver Beacons und Sessions, wodurch laufende Verbindungen überwacht und gesteuert werden können.

4.1.3 Implantate

- Payload der ausgeführt wird, um C2-Kommunikation zu etablieren - Beacon vs Session basierte Modelle - plattformübergreifend (Windows, Linux, macOS)

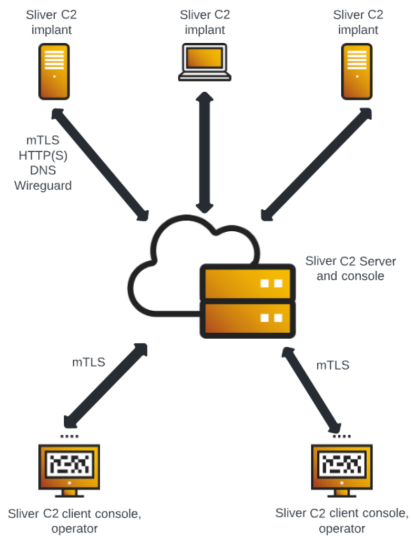

Abbildung 4: Server-Client Modell

4.2 Kommunikation

- (HTTP, HTTPS, DNS, etc.)

4.2.1 Payloads

- Staged vs. Stageless - Cross Compilation - Verschiedene Shell-Typen (Reverse Shell, Bind Shell, etc.)

4.2.2 Post-Exploitation

- Privilige Escalation - Enumeration - Persistence - Lateral Movement - Pivoting - Data Exfiltration

4.3 Stealth und OPSEC

- Verschleierungstechniken - Anti-Forensic Features - Erkennung von EDR/AV-Systemen

5 Vergleichende Gegenüberstellung der C2-Frameworks

In diesem Kapitel werden die zuvor vorgestellten C2-Frameworks anhand verschiedener Kriterien miteinander verglichen. Ziel ist es, die Stärken und Schwächen der einzelnen Tools herauszuarbeiten und eine fundierte Bewertung ihrer Eignung für unterschiedliche Anwendungsfälle im Red Teaming zu ermöglichen. Die Vergleichskriterien umfassen unter anderem die Benutzerfreundlichkeit, die Flexibilität bei der Anpassung von Payloads, die Fähigkeit zur Umgehung von Sicherheitslösungen sowie die unterstützten Betriebssysteme und Protokolle. Durch diese vergleichende Analyse soll ein umfassender Überblick über die Leistungsfähigkeit der verschiedenen C2-Frameworks gegeben werden, um eine informierte Entscheidung bei der Auswahl des geeigneten Tools für spezifische Angriffsszenarien zu erleichtern.

5.1 Techischer Vergleich

- Kommunikationsprotokolle - Payload-Generierung - Modularität - Erweiterbarkeit

5.2 Detection und Blue-Team-Sicht

- Signaturen - Verhaltensbasierte Erkennung - Netzwerkverkehrsanalyse

5.3 Einsatzszenarien

- Wann Sliver sinnvoller ist - Wann msf ausreicht - warum cobalt strike in manchen Fällen die bessere Wahl sein könnte

6 Praxisbezug

6.1

7 Obfuscation als logische Weiterentwicklung

7.1 Identifizierte Schwachstellen moderner C2s

7.2 Motivation für Obfuscation

7.3 Ausblick auf kommende Praxisarbeit

8 Fazit

Literatur

[1] „Was ist Cyber Kill Chain? — Microsoft Security“, besucht am 18. Feb. 2026. Adresse: https://www.microsoft.com/de-de/security/business/security-101/what-is-cyber-kill-chain.

[2] „Was ist C2? Command-and-Control-Infrastruktur erklärt — Varonis“, besucht am 19. Feb. 2026. Adresse: https://www.varonis.com/de/blog/was-ist-c2.

[3] „Modules“, Metasploit Documentation Penetration Testing Software, Pen Testing Security, besucht am 24. Feb. 2026. Adresse: https://rapid7.github.io/metasploit-framework/docs/modules.html.

[4] „Sliver Docs: Architecture“, besucht am 25. Feb. 2026. Adresse: https://sliver.sh/docs?name=Architecture.

[5] „gRPC“, gRPC, besucht am 25. Feb. 2026. Adresse: https://grpc.io/.